

# WebStrike Lab

1. Identifying the geographical origin of the attack facilitates the implementation of geo-blocking measures and the analysis of threat intelligence. From which city did the attack originate?

```
(kali@kali)-[~]
$ curl ipinfo.io/117.11.88.124
{
  "ip": "117.11.88.124",
  "hostname": "dns124.online.tj.cn",
  "city": "Tianjin",
  "region": "Tianjin",
  "country": "CN",
  "loc": "39.1422,117.1767",
  "org": "AS4837 CHINA UNICOM China169 Backbone",
  "postal": "300000",
  "timezone": "Asia/Shanghai",
  "readme": "https://ipinfo.io/missingauth"
}
```

2. Knowing the attacker's User-Agent assists in creating robust filtering rules. What's the attacker's Full User-Agent?

The screenshot displays the WebStrike application interface. At the top, there's a status bar with a clock showing 00:48:25 and buttons for 'Extend Time', 'Report an Issue', and 'Need help? Ask on D'. Below this is a toolbar with icons for File, Edit, View, Go, Capture, and Analyze. The main window is titled 'WebStrike' and shows a Wireshark packet capture of an HTTP stream (tcp.stream eq 0) from WebStrike.pcap. The packet list on the left shows a packet from 117.11.88.124. The packet details pane on the right shows the full User-Agent string: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0.

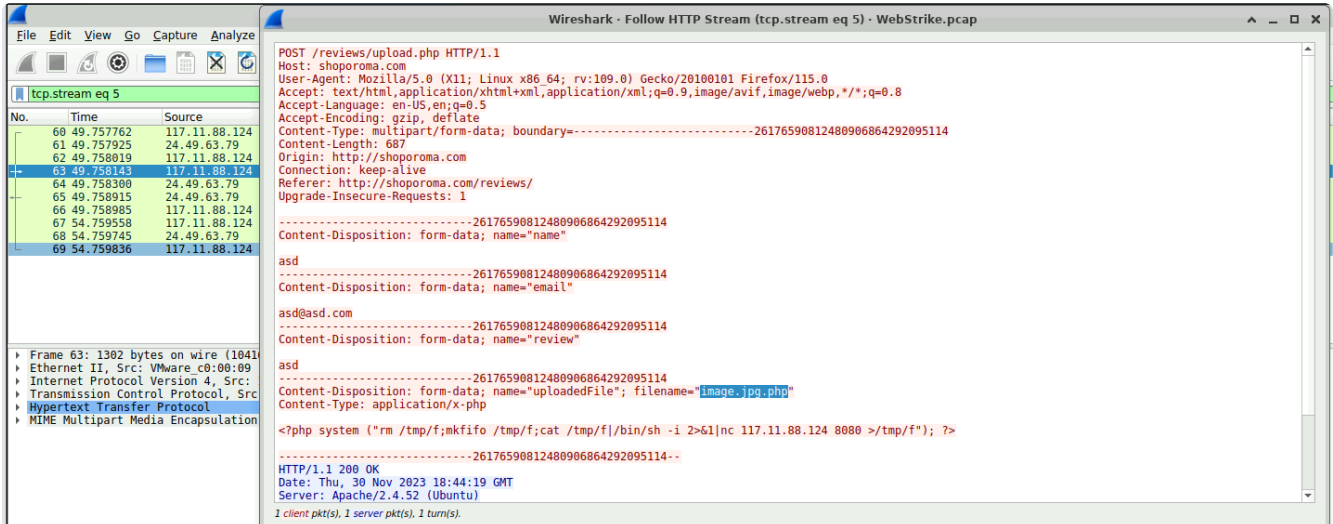
| No. | Time     | Source        |
|-----|----------|---------------|
| 1   | 0.000000 | 117.11.88.124 |
| 2   | 0.000139 | 24.49.63.79   |
| 3   | 0.000243 | 117.11.88.124 |
| 4   | 0.004936 | 117.11.88.124 |
| 5   | 0.004936 | 24.49.63.79   |
| 6   | 0.005337 | 24.49.63.79   |
| 7   | 0.005404 | 117.11.88.124 |
| 8   | 0.037487 | 117.11.88.124 |
| 9   | 0.037806 | 24.49.63.79   |
| 10  | 0.083834 | 117.11.88.124 |
| 11  | 4.435305 | 117.11.88.124 |
| 12  | 4.435764 | 24.49.63.79   |
| 13  | 4.435855 | 117.11.88.124 |
| 14  | 4.458038 | 117.11.88.124 |
| 17  | 4.458334 | 24.49.63.79   |
| 23  | 4.503816 | 117.11.88.124 |
| 25  | 9.458967 | 117.11.88.124 |

GET / HTTP/1.1  
Host: shoporoma.com  
User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate  
Connection: keep-alive  
Upgrade-Insecure-Requests: 1

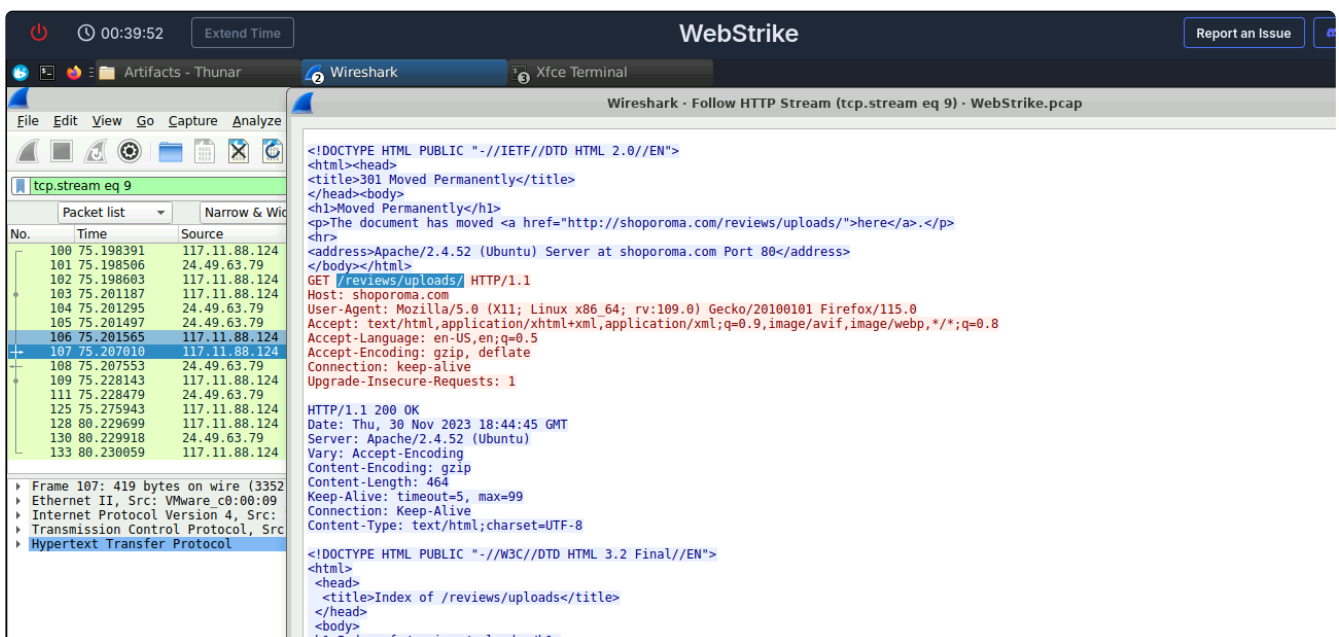
HTTP/1.1 200 OK  
Date: Thu, 30 Nov 2023 18:43:30 GMT  
Server: Apache/2.4.52 (Ubuntu)  
Last-Modified: Thu, 30 Nov 2023 16:49:26 GMT  
ETag: "348-60b616f4600c1-gzip"  
Accept-Ranges: bytes  
Vary: Accept-Encoding  
Content-Encoding: gzip  
Content-Length: 393  
Keep-Alive: timeout=5, max=100  
Connection: Keep-Alive  
Content-Type: text/html

<!DOCTYPE html>  
<html lang="en">

### 3. We need to determine if any vulnerabilities were exploited. What is the name of the malicious web shell that was successfully uploaded?



### 4. Identifying the directory where uploaded files are stored is crucial for locating the vulnerable page and removing any malicious files. Which directory is used by the website to store the uploaded files?



5. Which port, opened on the attacker's machine, was targeted by the malicious web shell for establishing unauthorized outbound communication?

|     |           |               |               |      |                                                                                                                   |
|-----|-----------|---------------|---------------|------|-------------------------------------------------------------------------------------------------------------------|
| 138 | 84.150547 | 117.11.88.124 | 24.49.63.79   | HTTP | 480 GET /reviews/uploads/image.jpg.php HTTP/1.1                                                                   |
| 139 | 84.150705 | 24.49.63.79   | 117.11.88.124 | TCP  | 66 80 → 46658 [ACK] Seq=1 Ack=415 Win=64768 Len=0 TSval=3033575201 TSecr=643907024                                |
| 140 | 84.153968 | 24.49.63.79   | 117.11.88.124 | TCP  | 74 54448 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3033575204 TSecr=0 WS=128                    |
| 141 | 84.154398 | 117.11.88.124 | 24.49.63.79   | TCP  | 74 8080 → 54448 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=643907028 TSecr=3033575204 WS=128 |
| 142 | 84.154497 | 24.49.63.79   | 117.11.88.124 | TCP  | 66 54448 → 8080 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3033575205 TSecr=643907028                                |
| 143 | 84.154602 | 24.49.63.79   | 117.11.88.124 | TCP  | 121 54448 → 8080 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=55 TSval=3033575205 TSecr=643907028                         |
| 144 | 84.154674 | 117.11.88.124 | 24.49.63.79   | TCP  | 66 8080 → 54448 [ACK] Seq=1 Ack=56 Win=65152 Len=0 TSval=643907028 TSecr=3033575205                               |
| 145 | 88.912034 | 117.11.88.124 | 24.49.63.79   | TCP  | 73 8080 → 54448 [PSH, ACK] Seq=1 Ack=56 Win=65152 Len=7 TSval=643911786 TSecr=3033575205                          |
| 146 | 88.912162 | 24.49.63.79   | 117.11.88.124 | TCP  | 66 54448 → 8080 [ACK] Seq=56 Ack=8 Win=64256 Len=0 TSval=3033579962 TSecr=643911786                               |

6. Recognizing the significance of compromised data helps prioritize incident response actions. Which file was the attacker attempting to exfiltrate?

```
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ uname -a
Linux ubuntu-virtual-machine 6.2.0-37-generic #38-22.04.1-Ubuntu SMP PREEMPT_DYNAMIC Thu Nov  2 18:01:13 UTC 2 x86_64 x86_64 x86_64 GNU/Linux
$ pwd
/var/www/html/reviews/uploads
$ ls /home
ubuntu
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105:/:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111:/:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:/nonexistent:/usr/sbin/nologin
_iss:x:106:113:TPM software stack,,,:/var/lib/tpm:/bin/false
77 client pkt(s), 6 server pkt(s), 12 turn(s).
Entire conversation (3523 bytes) Show data as ASCII Stream 13
Find:
Filter Out This Stream Print Save as... Back X Close Help
```